SIZMA TESTİ RAPORU

Rapor Tarihi	30/09/2026
Hazırlayan	Ömer Faruk Baysal
Test Hedefi	PortSwigger Web Academy Lab

1. DOM based cookie manipulation

Bu raporda, PortSwigger Web Security Academy'de yer alan DOM based cookie manipulation zafiyetine ilişkin lab ele alınmıştır.

2. Yönetici Özeti

Yapılan güvenlik testinde, hedef uygulamanın istemci tarafı JavaScript kodunda DOM tabanlı cookie manipülasyon zafiyeti tespit edilmiştir. Blog sayfasında yer alan son ürünleri listele özelliğindeki değişkenin, cookie değerine herhangi bir doğrulama olmadan url'i eklediği ve bunu href'e aktardığı tespit edilmiştir.

Zafiyet bir PoC ile doğrulanmıştır. Manipüle edilebilen çerez değeri, ana sayfada bir bağlantının href özniteliğine kodlanmadan yansıtıldığından, saldırgan bu yolla kurbanın tarayıcısında keyfi JavaScript çalıştırabilmektedir (XSS). Bu, oturum çerezlerinin çalınmasına ve hesabın ele geçirilmesine yol açabileceğinden zafiyetin giderilmesi önerilmektedir.

3. Zafiyet Açıklaması

Hedef sitenin blog sayfasında yer alan son ürünleri listele özelliğindeki değişkenin, cookie değerine herhangi bir doğrulama olmadan url'i eklediği ve bunu href'e aktardığı tespit edilmiştir. Bu değişkenin elle değerinin değiştirilebildiği ve zafiyete açık olduğu gözlemlenmiştir.

4. Risk Seviyesi

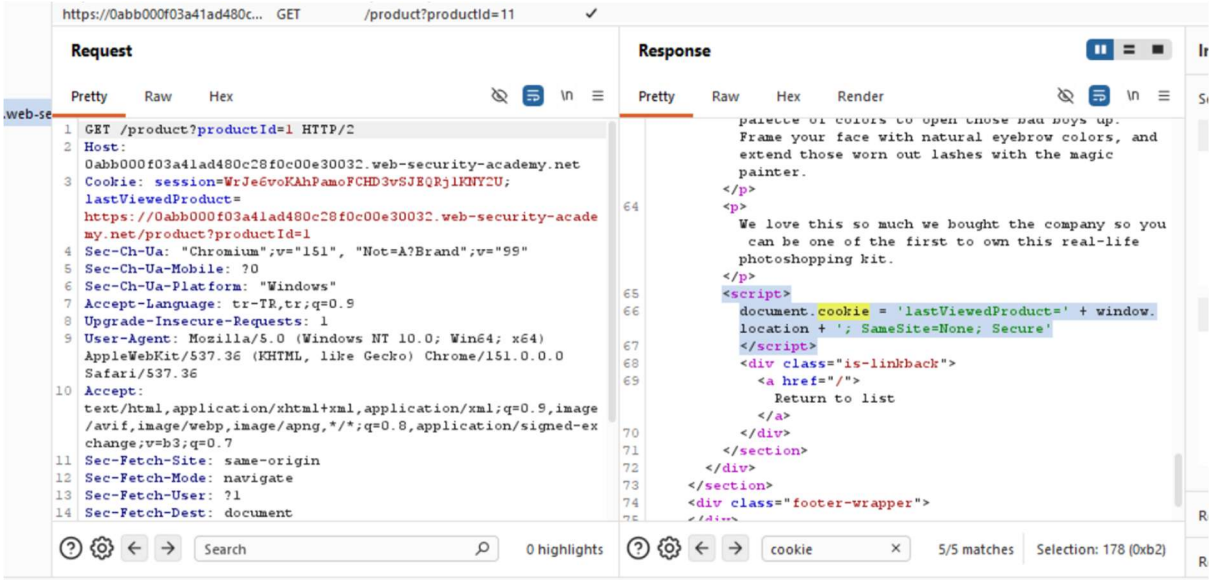
Risk Seviyesi	Orta
CVSS v3.1 Skoru	6.1
CWE	CWE-79

5. Etki

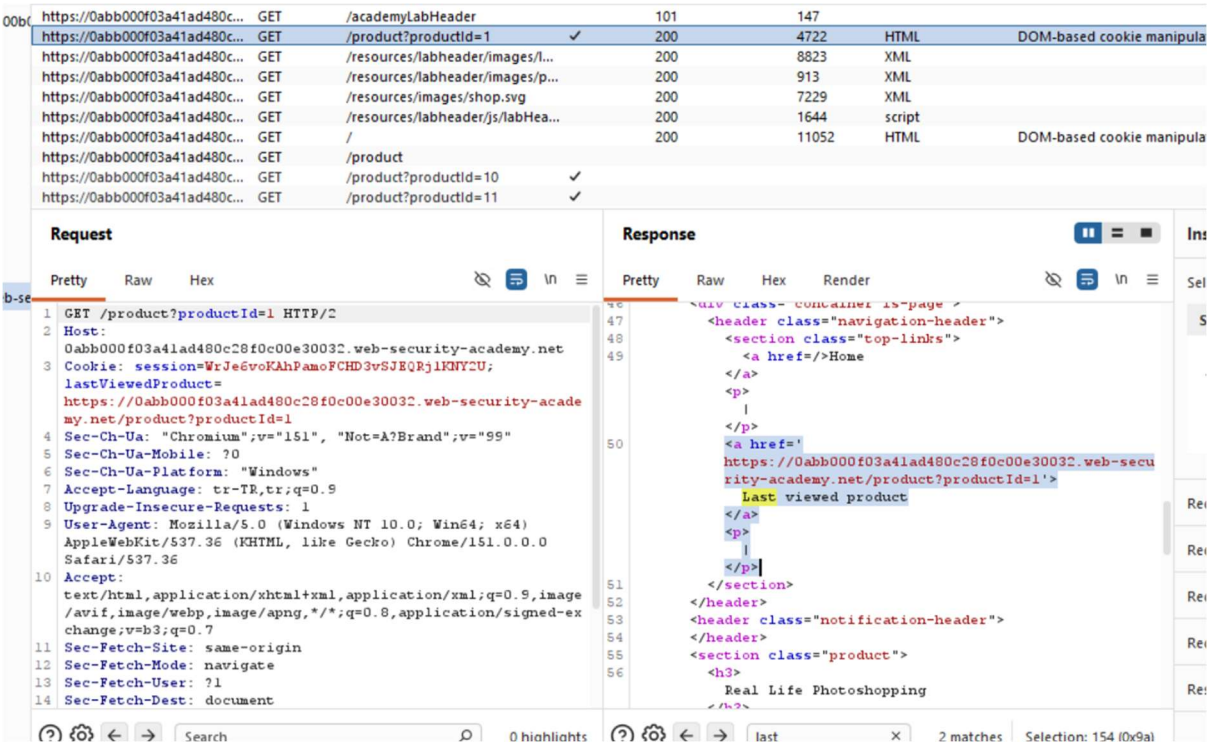
Zafiyetin başarıyla istismar edilmesi durumunda saldırgan, kurbanın tarayıcısında, hedef uygulamanın kaynağı (origin) bağlamında keyfi JavaScript çalıştırabilmektedir. Saldırı, kurbanın yalnızca saldırgan kontrolündeki bir sayfayı ziyaret etmesiyle gerçekleşmektedir. İstemci tarafında keyfi betik çalıştırılabilmesi; uygulama bağlamında erişilebilen oturum çerezlerinin veya diğer hassas verilerin çalınmasına, kurban adına uygulama üzerinde işlem yapılmasına ve nihayetinde hesabın ele geçirilmesine olanak tanıyabilir. Bu bulgu ayrıca, tek başına düşük etkili görünen bir çerez manipülasyonunun, güvensiz bir yansıtma noktasıyla birleştiğinde nasıl yüksek etkili bir XSS'e dönüşebildiğini göstermesi açısından önemlidir.

6. Proof Of Concept

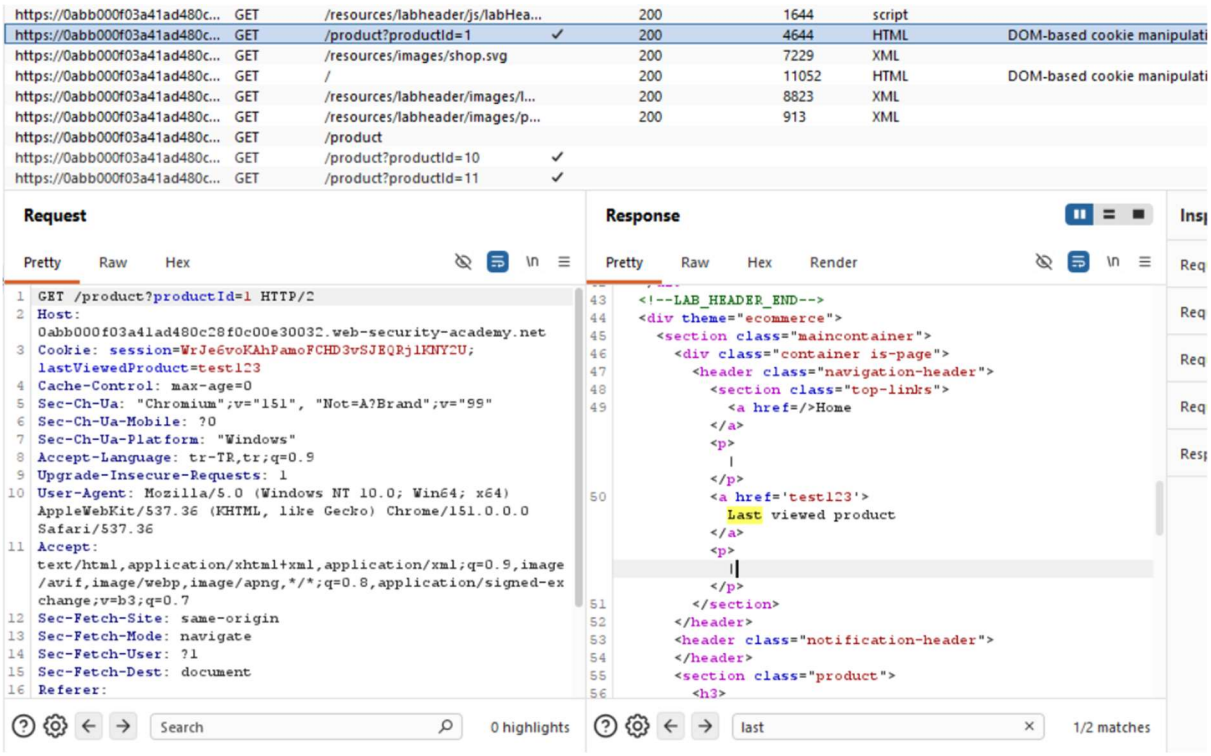
Hedef site incelendiğinde ana sayfada herhangi bir zafiyetle karşılaşılmamıştır. İlgili sitede bir blog gönderisi sayfası incelendiğinde ise yer alan son ürünleri listele özelliğindeki değişkenin, cookie değerine herhangi bir doğrulama olmadan url'i eklediği ve bunu href'e aktardığı tespit edilmiştir. Bu değişkenin elle değerinin değiştirilebildiği ve zafiyete açık olduğu gözlemlenmiştir.



Bu değişkenin elle değerinin değiştirilebildiği ve href etiketine gönderildiği gözlemlenmiştir.



Tarayıcı console kısmında " document.cookie = "lastViewedProduct=test123" " ile bu değişkenin değerinin değiştirilebildiği kanıtlanmıştır.



Url'in sabit olmadığı, çerezden gelen son ziyret edilen url ile değiştiği (windows.location) gözlemlenmiş olup buradaki değerin elle değiştirilmesi sonucu herhangi bir doğrulama olmamasının zafiyete yol açtığı tespit edilmiştir.

<iframe src="https://0abb000f03a41ad480c28f0c00e30032.web-security-academy.net/product?productId=1&'><script>print()</script>" onload="if(!window.x)this.src='https://0abb000f03a41ad480c28f0c00e30032.web-security-academy.net';window.x=1;">

Payload'ın iki aşamalı çalışması gerekmektedir. <iframe> ilk yüklendiğinde payload'lı ürün URL'ini açar; bu, payload'ı lastViewedProduct çerezine yazar. Ardından onload olayı this.src'yi ana sayfaya çevirir (window.x guard'ı bunu yalnızca bir kez yapar). İkinci yüklemede ana sayfa çerezi okuyup href'e bastığında href kırılır ve print() çalışır. Böylece çerez manipülasyonunun XSS'e dönüştüğü doğrulanmıştır.

7. Çözüm Önerisi

Çerez değerleri DOM'a yazılmadan önce kodlanmalıdır. Bir çerezden okunan değer, HTML bağlamına (ör. bir href özniteliği) yazılmadan önce bağlama uygun biçimde HTML-encode edilmeli; böylece değerin öznitelik/etiket sınırlarını kırması engellenmelidir.

Kaynaklardan gelen veri çereze yazılmadan önce doğrulanmalıdır. window.location gibi kısmen kullanıcı kontrolünde olan kaynaklar, document.cookie'ye doğrulanmadan/temizlenmeden yazılmamalıdır.

İçerik Güvenliği Politikası (CSP) uygulanmalıdır. Uygun bir Content-Security-Policy, olası bir enjeksiyonun etkisini savunma derinliği ilkesiyle azaltır.

8. Sonuç

Yapılan test sonucunda, hedef uygulamanın window.location kaynağını doğrulamadan bir çereze yazması ve bu çerez değerini ana sayfada bir bağlantının href özniteliğine kodlamadan yansıtması nedeniyle DOM tabanlı çerez manipülasyonu yoluyla XSS'e açık olduğu tespit ve kavram kanıtı ile doğrulanmıştır. Zafiyet, kurbanın tarayıcısında keyfi JavaScript çalıştırılmasına ve buna bağlı olarak oturum/hesap ele geçirmeye kadar ilerleyebilecek etkisi nedeniyle giderilmesi gereken bir bulgu olarak değerlendirilmiştir.
